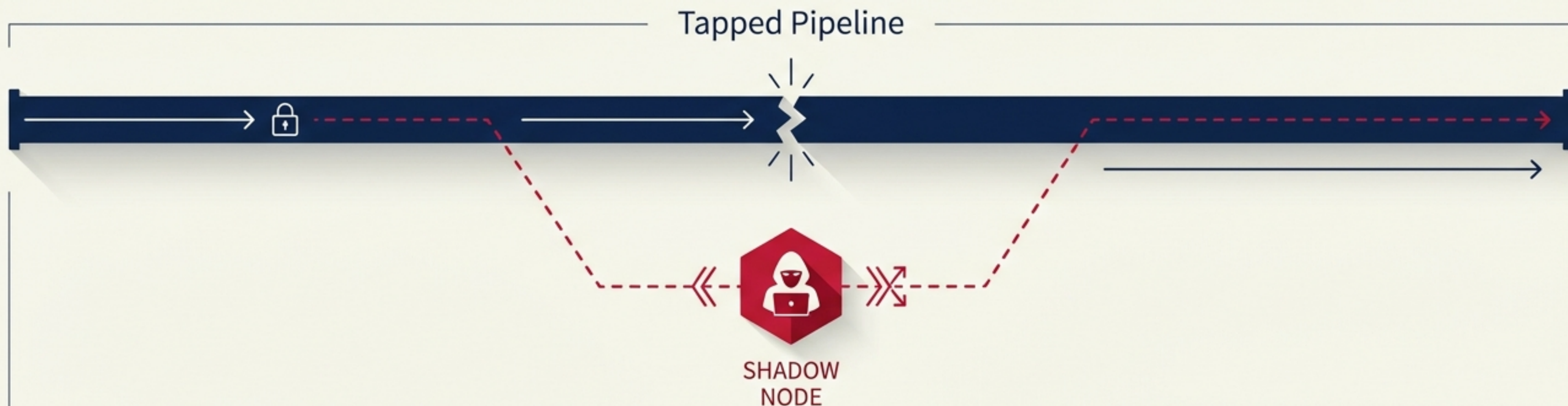


האנטומיה של מתקפת MITM (Man in the Middle)

כיצד תוקפים מייירטים מידע, מפענחים אותו, וכיצד ניתן לעצור אותם.



מבוסס על מחקרי האבטחה של Imperva

מהי מתקפת 'אדם באמצע' (MITM)?



התוקף ממקם את עצמו בחשאי בתוך ערוץ התקשורת בין המשתמש לאפליקציה. מטרתו להאזין בסתר או להתחזות לאחד הצדדים, מבלי לעורר חשד.

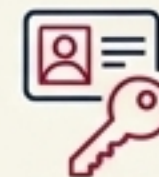


דמיינו דורך שפותח את מעטפת פירוט האשראי שלכם, מעתיק את המספרים, אוטם את המעטפה מחדש ומוסר אותה ליעד. התקשורת הושלמה, אך המידע שלכם נחשף.

הנכסים שבכוונת התוקף

סוגי המידע (Data Targets):

פרטי התחברות (Credentials), נתונים פיננסיים, מספרי כרטיסי אשראי.



מטרות עסקיות (Business Targets):

אפליקציות פיננסיות, פלטפורמות SaaS, אתרי איקומרס (E-commerce).



נזק מיידי (Immediate Impact):

גניבת זהות, העברות כספים לא מאושרות, שינוי סיסמאות זדוני.



איום מתקדם (Advanced Threat):

שימוש במידע שנגנב כדי לבסס דריסת רגל (Foothold) בתוך הרשת הארגונית, כשלב חדירה במתקפת APT.



הארכיטקטורה של המתקפה: תהליך דו-שלבי

כדי שמתקפת MITM תצליח, התוקף חייב להשלים שתי פעולות עוקבות בהצלחה:



שלב 2: פענוח (Decryption)

פריצת ההצפנה הדו-כיוונית (SSL/TLS) כדי לקרוא את התוכן, מבלי להפעיל התראות אבטחה בדפדפן או בשרת.



שלב 1: יירוט (Interception)

הטיית תעבורת הרשת של המשתמש כך שתעבור דרך הרשת של התוקף לפני שתגיע ליעדה.

שלב 1: יירוט - פאסיבי לעומת אקטיבי



הגישה האקטיבית: התחזות (Spoofing)

- טקטיקות אקטיביות בהן התוקף מתערב בפרוטוקולי הרשת עצמם.
- משיכת תעבורה לגיטימית אל מסלול התוקף באמצעות הונאת המערכת.
- דורש ידע טכני מתקדם כדי לשטות בתשתיות התקשורת.



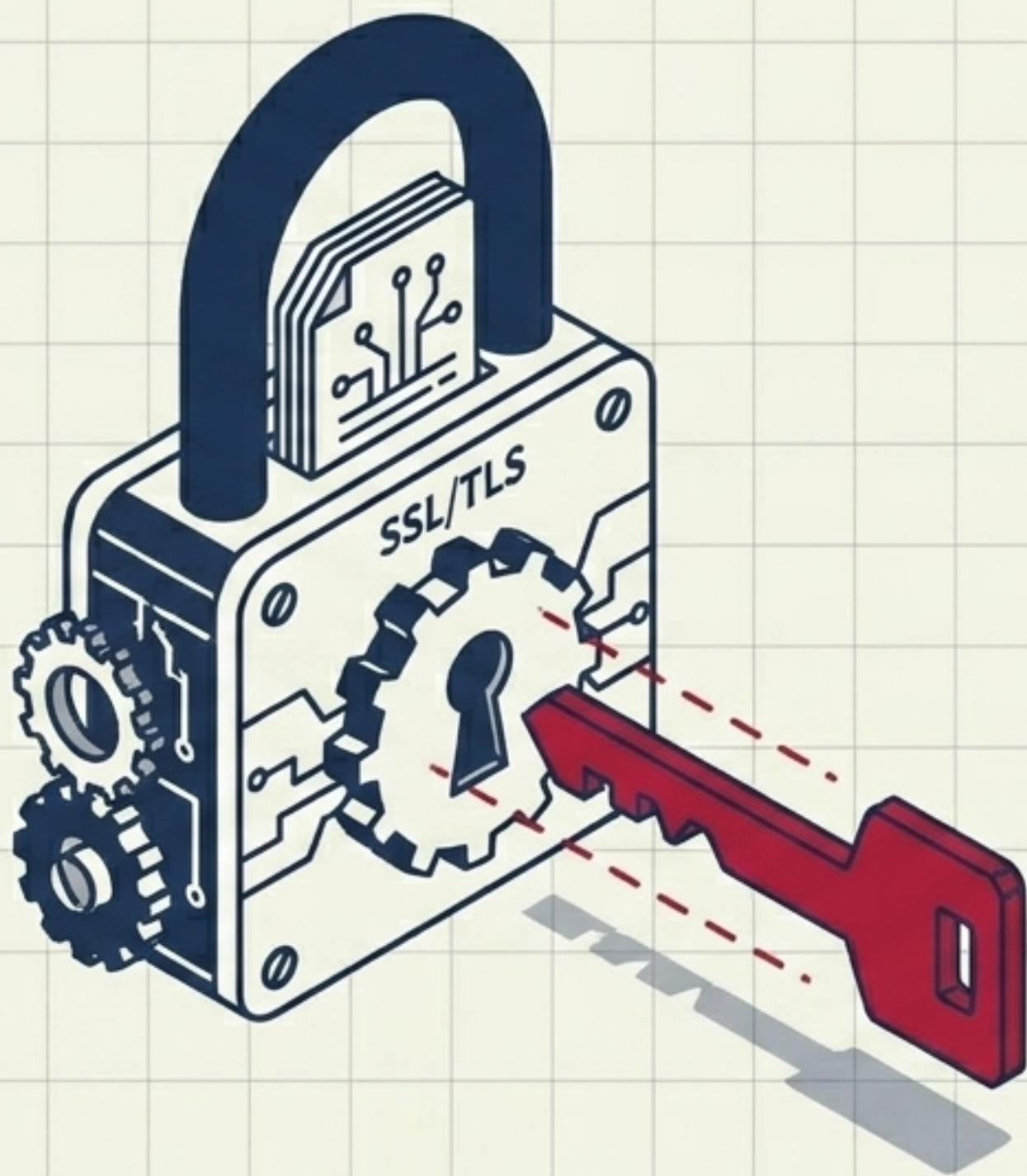
הגישה הפאסיבית: הרשת הפתוחה

- הקמת נקודות חמות (Wi-Fi Hotspots) ציבוריות וזדוניות, ללא סיסמה.
- שימוש בשמות תמימים (התואמים למיקום).
- ברגע שהקורבן מתחבר, לתוקף יש נראות מלאה על כל חילופי הנתונים ברשת.

מטריצת טכניקות היירוט (Active Spoofing)

סוג המתקפה	וקטור הפעולה	מנגנון ההונאה
IP Spoofing •	כותרות מנות המידע (Packet Headers)	התוקף מתחזה לאפליקציה על ידי שינוי כותרות ה-IP. משתמשים המנסים לגשת ל-URL לגיטימי מנותבים לאתר התוקף.
ARP Spoofing •	רשת מקומית (LAN)	קישור כתובת ה-MAC של התוקף לכתובת ה-IP של המשתמש באמצעות הודעות ARP מזויפות. המידע נשלח לתוקף במקום ליעד.
DNS Spoofing •	שרת ה-DNS (Cache Poisoning)	חדירה לשרת DNS ושינוי רשומות האתר. השרת המורעל מפנה את כל המשתמשים לאתר מתחזה.

שלב 2: אתגר הפענוח (The Decryption Challenge)



היירוט הוא רק חצי מהעבודה.
גם כאשר התעבורה עוברת דרך
התוקף, התקשורת הדו-כיוונית
לרוב מוצפנת (SSL/TLS).

כדי שמתקפת ה-MITM תצליח, על
התוקף לפענח את המידע 'על חם' -
כל זאת מבלי לעורר התראות אבטחה
בדפדפן של המשתמש או במערכות
האפליקציה.

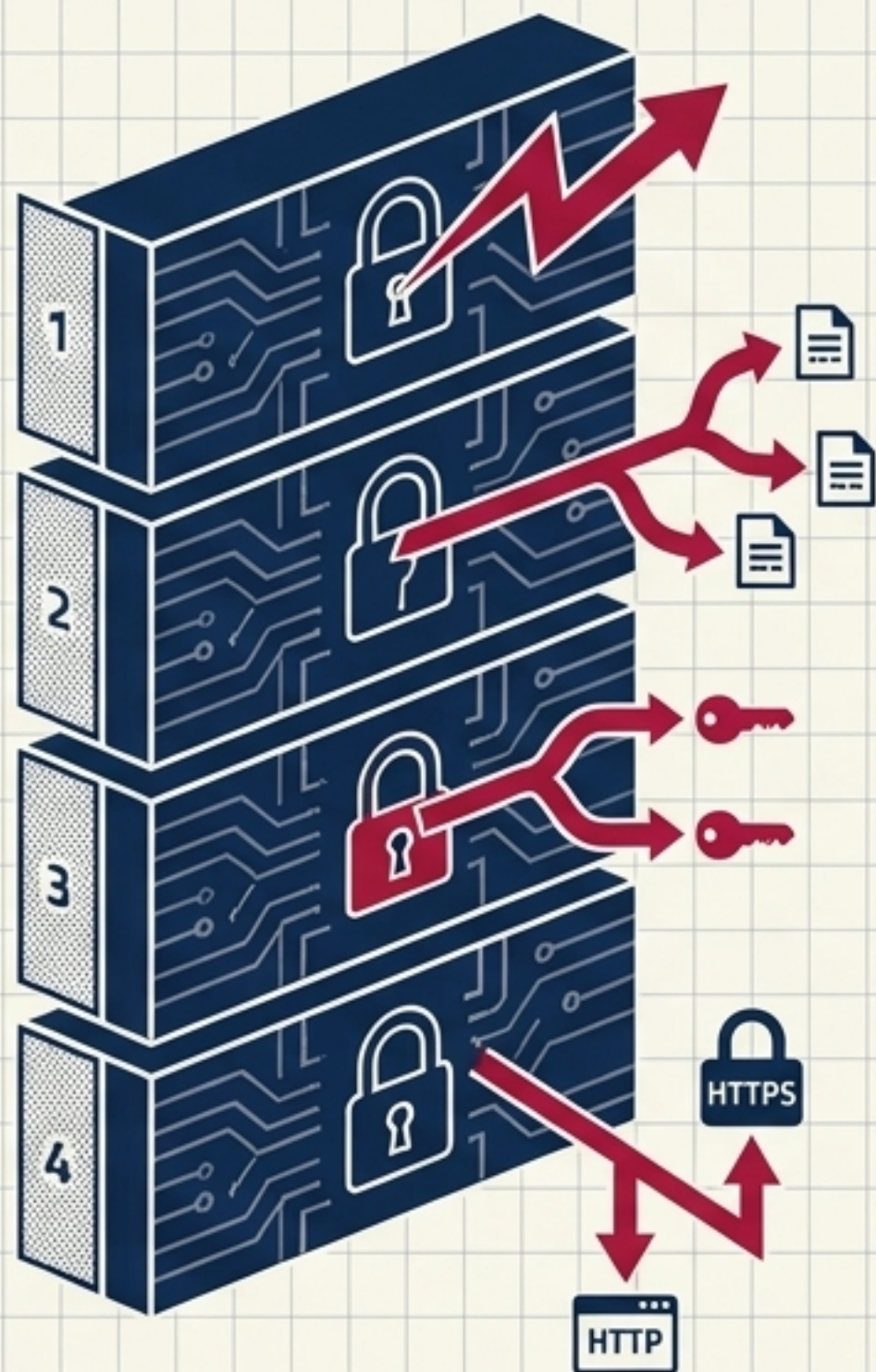
ארסנל פיצוח ההצפנה (SSL Vulnerabilities)

זיוף תעודות (HTTPS Spoofing): שליחת תעודה דיגיטלית מזויפת בעלת טביעת אצבע שמתחזה לאפליקציה אמينة. התוקף נחשף לנתונים לפני שהם מועברים לשרת האמיתי.

ניצול חולשות פרוטוקול (SSL BEAST): ניצול חולשה ב-TLS 1.0. הזרקת קוד JavaScript זדוני שמפענח ונא עוגיות מבוססות הצפנת CBC ואסימוני אימות.

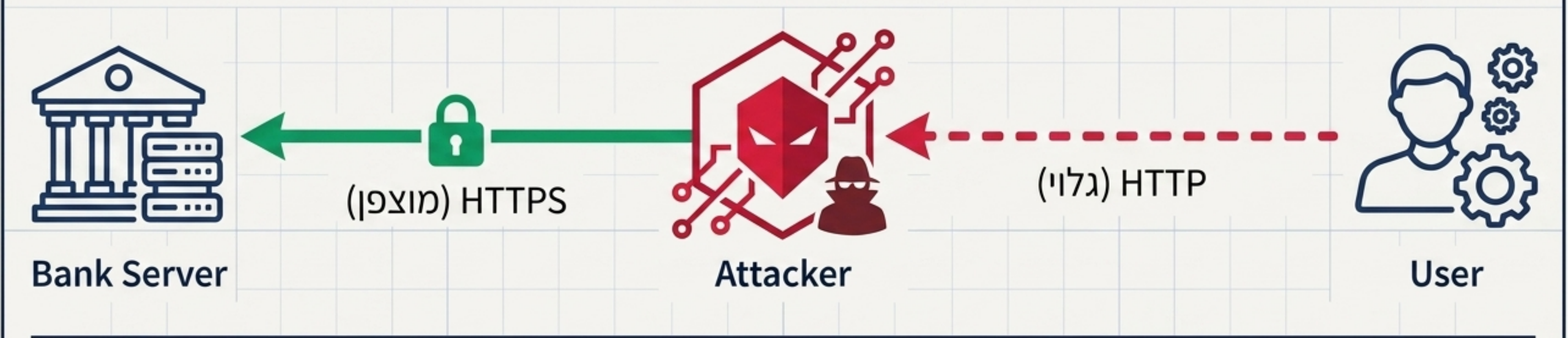
חטיפת מפתחות (SSL Hijacking): העברת מפתחות אימות מזויפים לשני הצדדים במהלך ה-TCP Handshake. התוקף שולט לחלוטין בתקשורת שנדמית כמאובטחת.

הנמכת פרוטוקול (SSL Stripping): הורדת התקשורת מ-HTTPS ל-HTTP מול המשתמש, תוך שמירת חיבור מאובטח מול השרת. (פירוט בשקף הבא).



אנטומיה של הנמכת פרוטוקול (SSL Stripping)

מתקפה מתוחכמת המפרקת את ההגנה (Downgrade Attack)



1. התערבות

התוקף מיירט את בקשת האימות (TLS) מהשרת למשתמש.

2. תרגום מוליך שולל

התוקף מקים חיבור HTTPS מאובטח מול השרת הלגיטימי, אך מגיש למשתמש גרסת HTTP רגילה וגלויה של האתר.

3. התוצאה

השרת בטוח שהחיבור מאובטח, המשתמש לא מבחין בשינוי, והתוקף קורא את כל פרטי ה-Session באופן גלוי.

אסטרטגיות מניעה: קו הגנה כפול

אחריות האפליקציה (הצפנה ואימות)



- הטמעת פרוטוקולי תקשורת מאובטחים (TLS ו-HTTPS) ברמה ארכיטקטונית.
- הצפנת כלל דפי האתר – לא רק עמודי התחברות (Login) – כדי למנוע גניבת עוגיות בזמן גלישה.

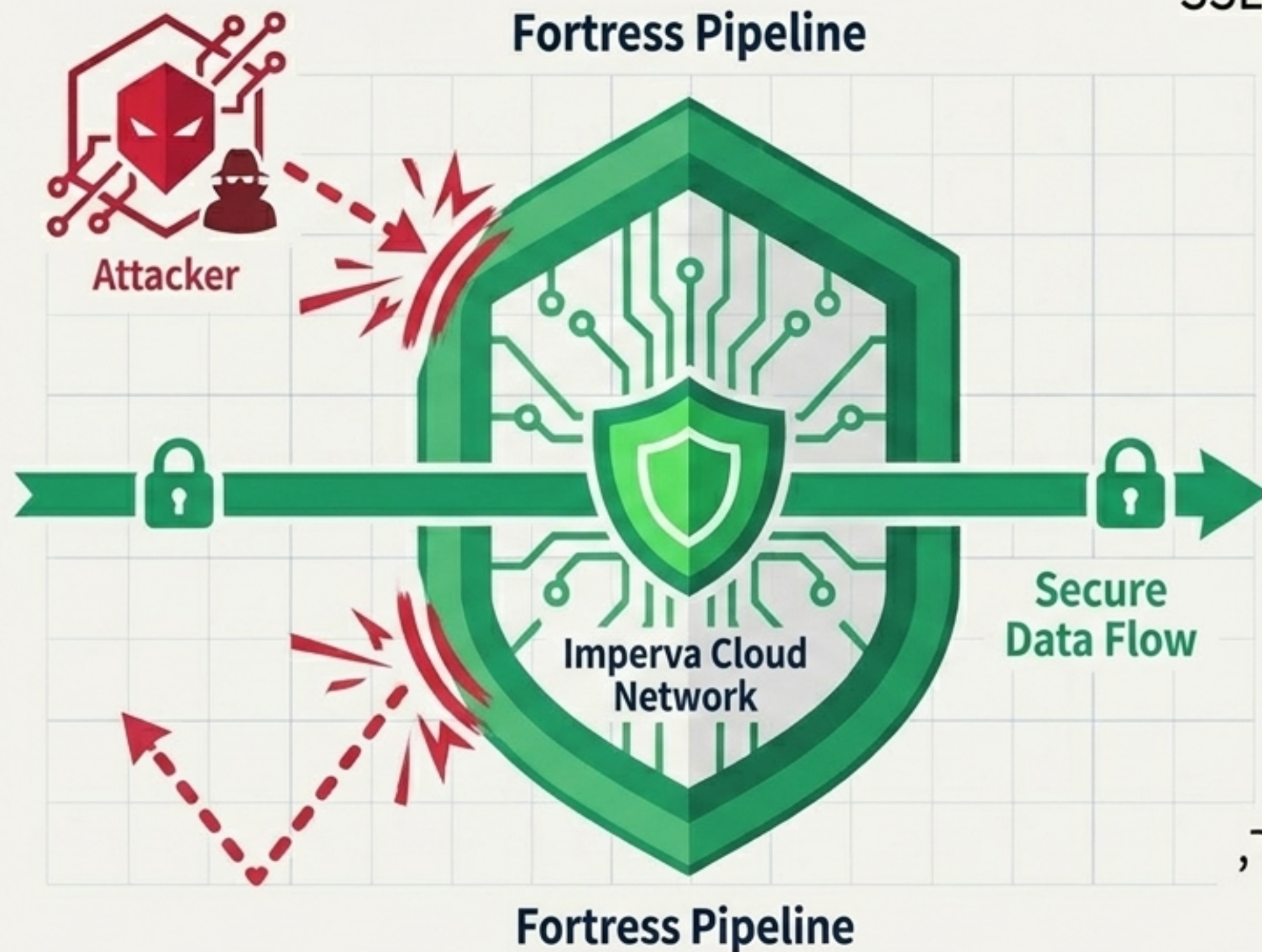
אחריות המשתמש (היגיינת רשת)



- הימנעות מחיבור לרשתות Wi-Fi ציבוריות ללא סיסמה.
- ערנות להתרעות דפדפן על אתרים שאינם מאובטחים.
- התנתקות יזומה מאפליקציות רגישות מיד בסיום השימוש.

הפתרון המקיף: מטריית ההגנה של Imperva

רוב מתקפות ה-MITM נובעות מהטמעת SSL/TLS לקויה או שימוש בצפנים מיושנים. Imperva מחסלת את וקטורי התקיפה הללו.



• הצפנה מקצה-לקצה:

ניהול סרטיפיקטים אופטימלי על גבי רשת ה-CDN, מבי רשת ה-CDN, החוסם מתקפות פשרה ופגיעויות פרוטוקול.

• מניעת SSL Stripping:

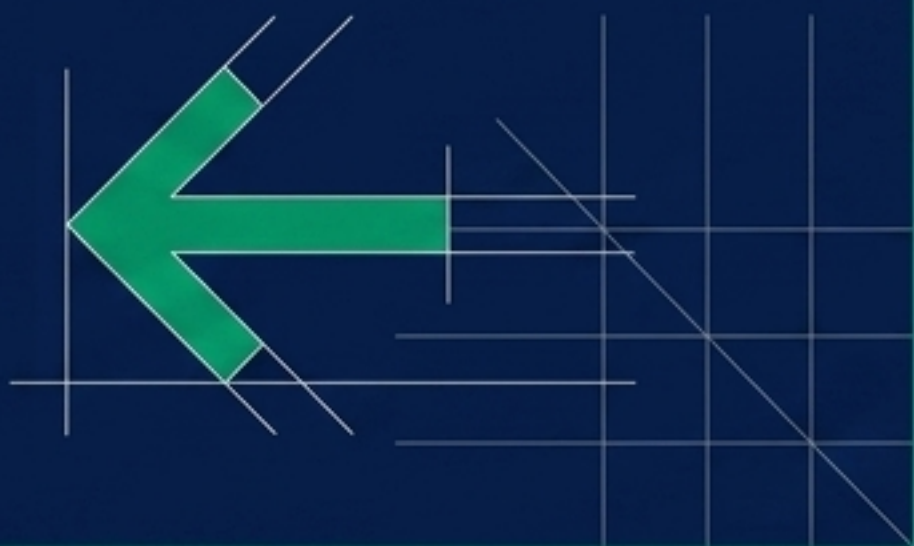
אכיפת מדיניות HSTS דרך לוח הבקרה כדי לחייב תקשורת SSL/TLS בכל תתי-הדומינים.

• שירות מנוהל (Managed Service): עדכון

תצורה אוטומטי העומד בדרישות המחמירות ביותר, ללא צורך בהתערבות ידנית.

סיכום מנהלים

**גלה את פתרונות
אבטחת האפליקציות
של Imperva -
תאם פגישת הדגמה
(Demo) עכשיו.**



- - מתקפות 'אדם באמצע' התפתחו מיירוט פאסיבי בבתי קפה למניפולציות פרוטוקול מורכבות.
- - הסתמכות על ערנות המשתמש בלבד מהווה סיכון עסקי בלתי קביל.
- - הגנה אמיתית דורשת ארכיטקטורת רשת חסינה, ניהול הצפנה עדכני, ומערכת המונעת אקטיבית שדרוג לאחור.